



INTERNSHIP REPORT CYBER SECURITY ANALYST

MARYAM REHAN

WEEK 03 Web Enumeration & Hidden Content Discovery

Introduction

The objective of this practical was to perform structured web enumeration on an authorized vulnerable lab environment and identify publicly accessible services, directories, files, and other useful information.

The assessment was performed in a controlled TryHackMe lab using the AttackBox. Nmap was used for service enumeration, while Gobuster was used for directory and file discovery. Curl was then used to manually verify selected findings.

Target and Lab Setup:

Lab Environment:

TryHackMe authorized vulnerable web application lab

Attacker Machine:

TryHackMe AttackBox

Target IP:

10.129.187.199 the target was first scanned to identify open ports and running services.

Tools Used:

- Nmap 7.94SVN – port and service enumeration
- Gobuster 3.6 – web directory/file discovery
- cURL – manual verification of web resources
- TryHackMe AttackBox – controlled testing environment

SCREEN SHOTS:

```
root@ip-10-129-138-0:~  
File Edit View Search Terminal Help  
root@ip-10-129-138-0:~# ^C  
root@ip-10-129-138-0:~# nmap -sV 10.129.187.199  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-24 22:19 UTC  
Nmap scan report for ip-10-129-187-199.eu-west-3.compute.internal (10.129.187.199)  
Host is up (0.00035s latency).  
Not shown: 996 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)  
53/tcp    open  domain   dnsmasq 2.90  
80/tcp    open  http     nginx 1.18.0 (Ubuntu)  
9999/tcp  open  http     nginx 1.18.0 (Ubuntu)  
MAC Address: 0A:FF:EB:10:19:37 (Unknown)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 6.92 seconds  
root@ip-10-129-138-0:~#
```

Figure 1: Nmap service and port enumeration of the authorized lab machine

```
root@ip-10-129-138-0:~# curl -I http://10.129.187.199  
HTTP/1.1 404 Not Found  
Server: nginx/1.18.0 (Ubuntu)  
Date: Thu, 24 Sep 2026 22:23:31 GMT  
Content-Type: text/html; charset=UTF-8  
Connection: keep-alive  
X-FLAG: THM{HEADER_FLAG}  
X-FLAG: THM{HEADER_FLAG}  
X-Powered-By: THM-Framework  
  
root@ip-10-129-138-0:~# curl -I http://10.129.187.199:9999  
HTTP/1.1 200 OK  
Server: nginx/1.18.0 (Ubuntu)  
Date: Thu, 24 Sep 2026 22:24:46 GMT  
Content-Type: text/html  
Content-Length: 509  
Last-Modified: Fri, 01 May 2026 21:46:56 GMT  
Connection: keep-alive  
ETag: "69f51f50-1fd"  
Accept-Ranges: bytes
```

Figure 2: HTTP response headers revealing a test flag and framework information

```
root@ip-10-129-138-0:~# curl http://10.129.187.199:9999
<!DOCTYPE html>
<html>
<head><title>Acme IT Support</title></head>
<body>
<h1>Acme IT Support</h1>
<p>We provide world-class IT support services. <a href="/contact">Contact us</a> to find out how we can help.</p>
<nav><ul>
  <li><a href="/services">Services</a></li>
  <li><a href="/about">About</a></li>
  <li><a href="/contact">Contact</a></li>
  <li><a href="/staff-portal">Staff Portal</a></li>
</ul></nav>
<!-- THM-Framework version 1.2. For help refer to the documentation at /docs/ -->
</body>
</html>
root@ip-10-129-138-0:~#
```

Figure 3: Web page on port 9999 exposing application endpoints and a /doc/ reference

```
root@ip-10-129-138-0:~# which gobuster
/usr/bin/gobuster
root@ip-10-129-138-0:~# gobuster dir -u http://10.129.187.199:9999 -w /usr/share/wordlists/dirb/common.txt --exclude-length 0
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.187.199:9999
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] Exclude Length: 0
[+] User Agent: gobuster/3.6
```

```
[+] User Agent:      gobuster/3.6
[+] Timeout:        10s
=====
=
Starting gobuster in directory enumeration mode
=====
=
/development.log      (Status: 200) [Size: 216]
/docs                 (Status: 301) [Size: 178]
/index.html           (Status: 200) [Size: 509]
/monthly              (Status: 301) [Size: 178]
/robots.txt           (Status: 200) [Size: 47]
/sitemap.xml          (Status: 200) [Size: 366]
Progress: 4614 / 4615 (99.98%)
=====
=
Finished
=====
=
```

Figure 4: Gobuster directory enumeration revealing accessible web resources on port 9999

```
=
root@ip-10-129-138-0:~# curl http://10.129.187.199:9999/development.log
2023-10-01 12:00:00 - Development server started
2023-10-02 09:15:22 - Database migration completed
2023-10-03 14:30:00 - Admin user created: username=admin password=changeme
2023-10-04 11:00:00 - Debug mode enabled
root@ip-10-129-138-0:~#
```

Figure 5: Accessible development log exposing sensitive application information

```
root@ip-10-129-138-0:~# curl -i http://10.129.187.199:9999/robots.txt
HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Date: Thu, 24 Sep 2026 22:48:38 GMT
Content-Type: text/plain
Content-Length: 47
Last-Modified: Fri, 01 May 2026 21:46:56 GMT
Connection: keep-alive
ETag: "69f51f50-2f"
Accept-Ranges: bytes

User-agent: *
Allow: /
Disallow: /staff-portal
root@ip-10-129-138-0:~#
```

Figure 6: robots.txt revealing the restricted /staff-portal path

Important Findings:

Finding 1 – HTTP Header Information Disclosure

The HTTP response on port 80 exposed additional information through response headers, including X-FLAG and X-Powered-By.

How discovered:

The headers were identified using:

```
curl -I http://10.129.187.199
```

Security relevance:

Exposed headers can reveal framework or implementation information that may assist reconnaissance.

Accessibility:

The information was publicly returned by the web server without authentication.

Finding 2 – Hidden Web Resources

Gobuster discovered several web resources that were not all immediately visible from the main page:

- /development.log
- /docs
- /monthly
- /robots.txt
- /sitemap.xml

How discovered:

These resources were identified using Gobuster directory enumeration against port 9999.

Security relevance:

Unlinked or hidden resources can expose documentation, logs, development information, or other content that was not intended to be publicly discoverable.

Accessibility:

The discovered resources returned valid HTTP responses and were accessible for further investigation.

Finding 3 – Exposed Development Log

The /development.log file was directly accessible without authentication.

It contained development information including database migration activity, creation of an administrator account, a test/default password, and debug mode status.

How discovered:

Gobuster identified /development.log, after which it was manually verified using:

```
curl http://10.129.187.199:9999/development.log
```

Security relevance:

Publicly accessible development logs can expose sensitive application information and credential-related data.

Accessibility:

The file returned HTTP 200 and was accessible without authentication.

Additional Discovery – robots.txt:

The robots.txt file revealed the following path:

```
/staff-portal
```

The file contained a Disallow entry for this path.

This is useful reconnaissance information because it reveals the existence of a potentially sensitive application area. However, robots.txt is not an access-control mechanism and does not technically prevent users from requesting the path.

Challenge – Detailed Analysis of /development.log:

The /development.log finding was selected for further investigation because it was directly accessible and contained sensitive development information.

Gobuster first identified the file with an HTTP 200 response. It was then manually verified using cURL.

The file contained information about database migration, administrator account creation, a test password, and debug mode being enabled.

This demonstrates an information disclosure issue in the context of the authorized lab. Development logs containing credentials or internal configuration information should not be publicly accessible.

The finding was therefore considered a genuine security issue within the lab scenario, rather than normal public application behavior.

A production application should restrict access to development logs, avoid storing credentials in logs, remove unnecessary debug information, and apply appropriate access controls.

Conclusion:

This practical demonstrated the importance of structured web enumeration during security testing.

Nmap identified the target's open services and showed that web servers were running on ports 80 and 9999. Gobuster then discovered several directories and files, including /development.log, /docs, /monthly, /robots.txt, and /sitemap.xml.

Manual verification using cURL provided additional information and confirmed that some resources were directly accessible. The most significant finding was the publicly accessible development log containing sensitive development and credential-related information.

The exercise also demonstrated why enumeration results should be manually verified and analyzed rather than simply copied into a report.

